

1. Scope

This assessment reviews GreenLeaf's compliance with the General Data Protection Regulation (GDPR) (EU) 2016/679. The scope covers the processing of personal data (names, addresses, purchase history) collected from EU citizens via the GreenLeaf website and stored on AWS cloud infrastructure.

2. Methodology

A gap analysis was conducted by reviewing the current website presence, documented internal procedures, and IT infrastructure against key GDPR Articles (Articles 12, 13, 14, and 17).

3. Findings (The Gaps)

The assessment identified the following critical gaps (aligned to Risk Register ID: GR-005):

Gap ID	Issue	GDPR Article	Risk Level
GAP-01	No Privacy Policy published on the website. Customers are not informed about how their data is processed.	Art. 13 (Transparency)	Critical
GAP-02	No Cookie Consent banner. Tracking cookies are dropped without explicit user opt-in.	Art. 7 (Conditions for Consent)	Critical
GAP-03	No documented workflow for handling "Right to Erasure" requests. Customers cannot easily request data deletion.	Art. 17 (Right to Erasure)	Critical

4. Remediation Roadmap

To address these gaps, the following actions are recommended (Target Date: 23 August 2026):

- Privacy Policy:** Engage a freelance privacy lawyer to draft a GDPR-compliant policy.
- Cookie Banner:** Immediately install a standard opt-in Cookie Consent plugin on the website (Quick Win).
- Erasure Workflow:** Document a manual workflow: Customer emails privacy@greenleaf.com - > CEO forwards to CTO -> CTO deletes from AWS within 7 days.

5. Conclusion

GreenLeaf is currently non-compliant with GDPR. Immediate action is required to mitigate financial, legal, and reputational risks (Residual Risk Score: 20/25). The recommended 60-day roadmap will bring the company into alignment with EU regulations.